🎙️ SPEECH D'ENTRAÎNEMENT ORAL — BLOC 1 : GOUVERNANCE DATA & IA SPOTIFY

Certification Architecte en Intelligence Artificielle (RNCP 41993 — Niveau 7)
Durée du Speech : 15 Minutes Chrono *(suivi de 15 min de Q&A)*
Alignement Livrables (`01_LIVRABLES`) : Synchronisé à 100 % avec `04_Presentation_Executive_Gouvernance_Spotify.pptx` *(11 slides + 3 annexes)* et `02_Schema_Roles_et_Responsabilites_RACI_Spotify.pptx`.
Posture : Tu es le **Data & AI Governance Lead** de Spotify face au Comité Exécutif (COMEX). Ton discours est posé, fluide, structuré et orienté **risques business, conformité et ROI**.

⏱️ RÉCAPITULATIF DU CHRONO (15 MINUTES — SLIDES 1 À 11)

Chrono	Slide	Titre Exact de la Diapositive (`01_LIVRABLES`)	Compétence RNCP Validée
00:00 – 01:15	**Slide 1**	Titre : *Spotify Data & AI Governance Framework*	Cadrage Stratégique
01:15 – 02:35	**Slide 2**	*1. Évaluation de la Maturité des Données (Gartner & DMBOK)*	**C5** (Audit & Risques)
02:35 – 04:05	**Slide 3**	*2. Les 4 Menaces Critiques sur le Business Model de Spotify*	**C5** (Sanctions & Failles)
04:05 – 05:35	**Slide 4**	*3. Les 10 Politiques de Gouvernance des Données & IA (DMBOK)*	**C1** (Politiques Data/IA)
05:35 – 07:05	**Slide 5**	*4. Organisation Humaine & Matrice RACI Complète*	**C2** (Parties Prenantes)
07:05 – 08:35	**Slide 6**	*5. Modèle Organisationnel Cible : Le Centre d'Excellence (CoE) Hybride*	**C2** (Gouvernance Agile)
08:35 – 10:00	**Slide 7**	*6. Écosystème d'Outillage Technologique Intégré*	**C1** (Outillage Qualité/Sécu)
10:00 – 11:20	**Slide 8**	*7. Feuille de Route du Projet Pilote (6 Mois)*	**C1 & C2** (Déploiement)
11:20 – 12:40	**Slide 9**	*8. Acculturation, Sensibilisation & Inclusion du Handicap*	**C3** (Inclusivité & Handicap)
12:40 – 14:00	**Slide 10**	*9. Cadre d'Audit, KPIs Mathématiques & Impact Business (ROI)*	**C4** (Audits & Mesure)
14:00 – 14:45	**Slide 11**	*Conclusion Stratégique & Ouverture du Q&A (+ Annexes A, B, C)*	Synthèse COMEX

🗣️ TEXTE À LIRE À L'ORAL (STYLE PROMPTEUR FLUIDE)

🎧 SLIDE 1 — Introduction & Cadrage Exécutif *(⏱️ 00:00 – 01:15 | 1 min 15)*

> « Bonjour à tous. En tant que **Data et AI Governance Lead** chez Spotify, je vous présente aujourd'hui notre cadre stratégique et opérationnel de gouvernance des données et de l'intelligence artificielle.
>
> Spotify est aujourd'hui le leader mondial du streaming musical avec des centaines de millions d'utilisateurs actifs à travers **180 pays**. Mais cette hyper-croissance s'est construite dans l'urgence : nos équipes techniques — les *Tribes* — ont développé leurs pipelines sans cadre commun.
>
> Mon objectif pendant ces 15 minutes est très concret : vous montrer comment nous allons faire sortir Spotify de la gestion réactive en mode "pompier" pour ancrer une **gouvernance industrielle maîtrisée**, qui protège notre chiffre d'affaires, sécurise nos données bancaires et fiabilise nos algorithmes de recommandation. »

- 👉 **[Passer à la Slide 2]**

📊 SLIDE 2 — Étape 1 : Évaluation de la Maturité (Gartner & DMBOK) *(⏱️ 01:15 – 02:35 | 1 min 20)*

> « Pour poser un diagnostic objectif, j'ai audité les **9 dimensions du référentiel DMBOK** sur l'échelle de maturité de **Gartner** (qui va de 1 à 5).
>
> Cet audit met en lumière ce que j'appelle le **"Paradoxe Spotify"** :
>
> - D'un côté, deux dimensions purement technologiques atteignent le **Niveau 3** : notre **Data Architecture** (avec d'excellents Data Lakes et du streaming temps réel) et notre **Analytics & BI** (avec des dashboards d'écoute très puissants, même s'ils reposent souvent sur des tables non certifiées).
> - Mais de l'autre côté, toutes nos dimensions de gouvernance humaine, de qualité et de sécurité plafonnent au **Niveau 2 ("Réactif")**, ce qui bloque notre **maturité globale au Niveau 2 sur 5**.
>
> Concrètement, nous avons des défauts majeurs au niveau de la cellule — comme des formats de dates hétérogènes (`YYYY-MM-DD` vs `YYYY-DD-MM`) et des métadonnées musicales obsolètes —, une incapacité à réconcilier les logs marketing et produit, et un traitement manuel des demandes RGPD qui dépasse régulièrement le délai légal de 30 jours.
>
> Notre objectif cible à 12 mois est d'atteindre le **Niveau 4 Gartner ("Managed")**, piloté par des KPIs mesurables. »

- 🛡️ *Raccord 100 % Slide 2 : Tu distingues bien Data Architecture & BI (Niveau 3) des autres dimensions (Niveau 2) comme écrit sur ta slide.*
- 👉 **[Passer à la Slide 3]**

🚨 SLIDE 3 — Étape 1 : Les 4 Menaces Critiques sur le Business Model *(⏱️ 02:35 – 04:05 | 1 min 30)*

> « Rester au niveau 2 expose le modèle économique de Spotify à **4 menaces critiques** :
>
> 1. **Première menace : les silos de données et une vision fragmentée.** Le Marketing, la Curation et l'Engineering opèrent sur des bases cloisonnées sans identifiant utilisateur unifié. Il est impossible

d'avoir une vision 360° du parcours abonné, ce qui génère des doublons de ciblage publicitaire et des analyses divergentes.

2. **Deuxième menace : les sanctions réglementaires RGPD et CCPA sur 180 pays.** Ce n'est pas un risque théorique : en 2023, Spotify a été condamné à **5 millions d'euros d'amende** par l'autorité suédoise (**IMY**) pour non-respect du droit d'accès (Article 15 du RGPD). Si le traitement des demandes d'accès et de suppression (*SARs*) n'est pas automatisé sous 30 jours, nous encourons l'amende maximale de **4 % du chiffre d'affaires mondial**, soit plus de **500 millions d'euros**.
3. **Troisième menace : une faille critique de sécurité bancaire PCI-DSS.** Notre audit a révélé que des stagiaires et prestataires ont un accès direct en lecture à la table sensible `payment_details`. C'est une violation directe du principe de moindre privilège (Exigence 7 de PCI-DSS niveau 1), qui peut entraîner la suspension de notre autorisation d'encaissement par carte bancaire.
4. **Quatrième menace : la boîte noire IA face à l'EU AI Act.** Nos algorithmes de recommandation (*Discover Weekly*) sont entraînés sans traçabilité claire (*Lineage*) du consentement ni de l'âge, ce qui crée des biais de recommandation, augmente le désabonnement (*Churn*) et contrevient à l'EU AI Act. »

- 👉 **[Passer à la Slide 4]**

📜 SLIDE 4 — Étape 2 : Les 10 Politiques de Gouvernance (DMBOK) *(⏱ 04:05 – 05:35 | 1 min 30)*

« Pour répondre à ces menaces, j'ai institué **10 politiques opérationnelles contraignantes** alignées sur le DMBOK et applicables à toutes les Tribes :

- **Politiques 1 et 2 (Gouvernance & Architecture) :** Nomination obligatoire d'un *Data Owner* et d'un *Data Steward* par table critique, et interdiction totale du *Shadow IT* avec transit obligatoire par notre *Common Data Platform*.
- **Politiques 3 et 4 (Qualité Cellule & Sécurité PCI-DSS) :** Standard strict **ISO-8601 (`YYYY-MM-DD`)** sur toutes les dates avec typage forcé et contrôle *Talend* ; côté sécurité, **zéro accès stagiaire** sur la table bancaire et chiffrement fort **AES-256**.
- **Politiques 5, 6 et 7 (Conformité, APIs & Métadonnées) :** Automatisation des purges de Droit à l'Oubli sous **30 jours** via *OneTrust* et alerte de faille en **72 heures** ; interdiction des extractions manuelles ad-hoc au profit d'APIs certifiées ; et zéro dataset en production sans enregistrement dans le Data Catalog (*Collibra / OpenMetadata*).
- **Politiques 8, 9 et 10 (Stockage, Analytics & AI Trust) :** Rétention des logs fixée à **24 mois** et **interdiction stricte d'utiliser des données de production en environnement de développement** ; décisions stratégiques basées uniquement sur des **tables certifiées Gold** ; et enfin traçabilité immuable des datasets d'entraînement IA avec **DVC** et audits anti-biais. »

- 🛡️ *Raccord 100 % Slide 4 : Les 10 politiques suivent l'ordre et les chiffres exacts de ta Slide 4 (ISO-8601, AES-256, 30j/72h, 24 mois, tables Gold, DVC).*
- 👉 **[Passer à la Slide 5]**

👥 SLIDE 5 — Étape 2 : Organisation Humaine & Matrice RACI Complète *(⏱ 05:35 – 07:05 | 1 min 30)*

« Une politique ne fonctionne que si chacun sait qui décide et qui exécute. Sur la **Slide 5**, j'ai formalisé notre **matrice RACI** autour de **6 acteurs clés** :

- **Au niveau exécutif :** Le **CDO (Chief Data Officer)** est le décideur final (*Accountable [A]*) sur la définition des politiques globales (Ligne 1) et sur le Data Catalog (Ligne 6). Le **DPO (Data Protection Officer)** est quant à lui l'unique *Accountable [A]* sur l'automatisation des demandes RGPD *OneTrust* (Ligne 5) et sur l'audit éthique et conformité **AI Act** (Ligne 7).
- **Au sein des Tribes métier :** Je distingue clairement deux rôles :
- Les **Data Owners** (nos VP Métier : Marketing, Curation, Billing) sont **Accountable [A]** de l'attribution de l'ownership (Ligne 2), de la qualité au niveau cellule (Ligne 3) et des autorisations d'accès PCI-DSS sur la facturation (Ligne 4).
- Les **Data Stewards** sont les opérationnels terrain (**Responsible [R]**) qui implémentent les règles de qualité *Talend* et documentent les métadonnées dans *OpenMetadata*.
- **Au niveau technique :** Les **Data Custodians** (Data Engineers / SecOps) exécutent (**[R]**) la sécurité technique PCI-DSS et le chiffrement, tandis que les **AI Leads** (Model Owners et MLOps) exécutent (**[R]**) le lignage DVC/MLflow et les tests anti-biais.

Comme vous le voyez dans le tableau, chaque ligne comporte **un seul et unique décideur [A]**, ce qui garantit une imputabilité totale. »

- 🛡️ *Raccord 100 % Slide 5 : Chaque ligne citée (Lignes 1 à 7) correspond exactement aux lettres R, A, C, I du tableau de ta Slide 5 !*
- 👉 **[Passer à la Slide 6]**

🏛️ SLIDE 6 — Étape 3 : Le Modèle Organisationnel Cible — CoE Hybride *(⏱️ 07:05 – 08:35 | 1 min 30)*

« Comment déployer cette organisation sans casser l'agilité des Tribes de Spotify ? Sur la **Slide 6**, j'ai évalué les 3 modèles d'organisation :

1. **Le modèle Centralisé est refusé :** si une équipe unique devait valider chaque modification de table, cela créerait un goulet d'étranglement bureaucratique massif et ralentirait les cycles de *release* agile des Tribes.
2. **Le modèle Décentralisé est notre problème actuel :** laisser chaque Tribe gérer ses données en autonomie totale a généré l'anarchie des formats, la faille PCI-DSS des stagiaires et l'amende RGPD de 5 millions d'euros.
3. **J'ai donc retenu le Modèle en Centre d'Excellence (CoE) Hybride :**
4. Un **Hub Centralisé (coprésidé par le CDO et le DPO)** qui définit les standards, fournit l'outillage commun et arbitre les litiges.
5. Des **Squads Fédérées locales** : nos Data Stewards et Data Owners sont intégrés directement au cœur de chaque Tribe (Marketing, Curation, Facturation), complétés par notre **Guilde de Gouvernance IA**.

Bénéfice clé : **zéro ralentissement de l'innovation** tout en garantissant 100 % de conformité. »

- 👉 **[Passer à la Slide 7]**

🛠️ SLIDE 7 — Étape 3 : Écosystème d'Outillage Technologique Intégré *(⏱️ 08:35 – 10:00 | 1 min 25)*

> « Pour outiller ce Centre d'Excellence, la **Slide 7** présente nos **5 briques logicielles** alignées sur le DMBOK :
>
> 1. **Catalog & Lineage — *Collibra / OpenMetadata* :** répertoire unique des données de Spotify, recherche en libre-service, dictionnaire métier unifié et cartographie du *Data Lineage* de bout en bout.
> 2. **Qualité Cellule — *Talend Data Quality* :** profilage automatique des tables dès l'ingestion, application stricte du format de date ISO-8601, contrôle des plages de valeurs numériques et alerte immédiate vers les Data Stewards.
> 3. **Privacy & RGPD — *OneTrust* :** portail mondial des requêtes SARs, automatisation du Droit à l'Oubli sous 30 jours et registre des consentements utilisateurs et IA.
> 4. **Sécurité & PCI-DSS — *Splunk (SIEM)* :** surveillance continue des accès aux bases, blocage des accès non autorisés sur la table de facturation, alerting d'intrusion sous 72h et piste d'audit infalsifiable.
> 5. **Gouvernance IA — *DVC / MLflow* :** versionnage immuable des datasets d'entraînement IA, auditabilité des métadonnées du modèle *Discover Weekly* et détection des dérives et biais pour l'EU AI Act. »

- 👉 **[Passer à la Slide 8]**

🗓️ SLIDE 8 — Étape 3 : Feuille de Route du Projet Pilote (6 Mois) *(⏱️ 10:00 – 11:20 | 1 min 20)*

> « Plutôt qu'un déploiement "Big Bang" risqué, nous lançons sur la **Slide 8** un **projet pilote de 6 mois** centré sur le périmètre le plus critique : les **Données Abonnés et l'Entraînement de la Recommandation (*Discover Weekly*)**.
>
> Il se découpe en **3 phases de 2 mois** :
>
> - **Mois 1 à 2 (Phase 1 — Sanctuarisation & Socle) :** Révocation immédiate des accès stagiaires et comptes génériques sur `payment_details` avec chiffrement AES-256 ; déploiement d'*OpenMetadata* sur les **50 tables les plus critiques** ; et nomination des Data Stewards dans les Tribes Marketing et Curation musicale.
> - **Mois 3 à 4 (Phase 2 — Qualité & Conformité) :** Mise en production des contrôles *Talend* au niveau cellule (dates ISO-8601, complétude) ; connexion du portail *OneTrust* aux bases abonnés pour abaisser le délai de traitement du droit à l'oubli à **moins de 48 heures** ; et lancement des sessions de *Data Culture*.
> - **Mois 5 à 6 (Phase 3 — Gouvernance IA & Extension) :** Traçabilité intégrale des données d'entraînement sous *DVC/MLflow*, mise en place des audits anti-biais sur la diversité des artistes recommandés, et audit final validant le passage au **Niveau 4 Gartner ("Managed")** avant extension mondiale. »

- 👉 **[Passer à la Slide 9]**

♿ SLIDE 9 — Étape 3 : Acculturation, Sensibilisation & Inclusion du Handicap *(⏱️ 11:20 – 12:40 | 1 min 20)*

> « Sur la **Slide 9**, nous abordons le facteur humain : la distinction capitale entre le **Data Catalog** — qui est l'outil technique (*Collibra/OpenMetadata*) pour indexer la donnée — et la **Data Culture**, qui est la compétence humaine permettant à chaque salarié de comprendre sa responsabilité via des ateliers trimestriels.
>
> Conformément à nos engagements RSE et à la compétence C3 du référentiel, ce programme de formation est conçu pour être **100 % inclusif envers nos collaborateurs en situation de handicap** :
>
> 1. **Standard WCAG 2.1 niveau AA pour les outils de données :** Tous nos portails (*OpenMetadata*) et dashboards BI (*Tableau*) respectent le niveau WCAG 2.1 AA, avec des palettes certifiées pour les collaborateurs **daltoniens**, des contrastes validés et une navigation 100 % au clavier.
> 2. **Supports multimodaux (malentendants et malvoyants) :** Nos capsules vidéo de formation intègrent un **sous-titrage synchronisé systématique (fichiers VTT)** et des transcriptions textuelles complètes ; toute notre documentation est balisée en Markdown/HTML sémantique pour une lecture fluide via les lecteurs d'écran **NVDA et JAWS**.
> 3. **Méthode FALC & inclusion de la neurodiversité :** Nos chartes de conformité sont déclinées selon la règle **FALC (*Facile à Lire et à Comprendre*)** sous forme de fiches visuelles synthétiques pour accompagner 100 % des collaborateurs, quelles que soient leurs particularités cognitives. »

- 👉 **[Passer à la Slide 10]**

📈 SLIDE 10 — Étape 4 : Cadre d'Audit, KPIs Mathématiques & Impact Business (ROI) *(⏱️ 12:40 – 14:00 | 1 min 20)*

> « Sur la **Slide 10**, nous démontrons scientifiquement le passage du niveau 2 au niveau 4 Gartner et la rentabilité (ROI) du cadre autour de **4 indicateurs chiffrés** :
>
> 1. **Qualité des Données (`99,9 %`) : 99,9 %** des erreurs de typage et de dates sont bloquées dès l'ingestion, le temps moyen de résolution des anomalies (**MTTR**) passe sous la barre des **24 heures**, et nous atteignons zéro corruption de métadonnées dans *Discover Weekly*.
> 2. **Conformité & Légal (`0 €`) : 0 € d'amende RGPD / CCPA** (préservant plus de 500 millions d'euros de risque maximal), **100 % des requêtes SARs** traitées sous 30 jours, et certification PCI-DSS validée sans réserve.
> 3. **Efficacité des Équipes (`-70 %`) : -70 % de temps perdu** par nos Data Scientists à nettoyer et réconcilier la donnée, 100 % des tables de production documentées, et une mise en production des modèles IA **2 fois plus rapide**.
> 4. **Impact Client & Churn (`-20 %`) : -20 % de plaintes utilisateurs** liées à des recommandations inadéquates, augmentant la rétention des abonnés Premium et amortissant intégralement l'outillage et le CoE dès la première année. »

- 👉 **[Passer à la Slide 11]**

✨ SLIDE 11 — Conclusion Stratégique & Ouverture Q&A *(⏱️ 14:00 – 14:45 | 45 sec)*

> « En conclusion sur la **Slide 11**, la gouvernance des données et de l'IA que je vous propose est un véritable **accélérateur d'innovation** :
>
> - Spotify sort définitivement du mode pompier pour ancrer une gestion pilotée par la valeur au **Niveau 4 Gartner**.
> - Notre **Centre d'Excellence Hybride** préserve l'agilité des Tribes tout en sanctuarisant notre conformité dans 180 pays.
> - Et notre démarche est éthique et inclusive, avec une sensibilisation accessible à 100 % des salariés (**WCAG 2.1 AA / FALC**) et une anticipation proactive de l'**EU AI Act**.
>
> Je vous remercie pour votre attention, et je suis à votre disposition pour vos questions — avec également **3 slides d'annexes (Slides 12, 13 et 14)** prêtes sur le benchmark réglementaire, le Lineage IA de *Discover Weekly* et notre procédure de réaction en 72 heures en cas de violation de données. »

🛡️ UTILISATION DES 3 ANNEXES (SLIDES 12, 13, 14) PENDANT LE Q&A

1. **Si le jury questionne sur RGPD vs CCPA vs PCI-DSS vs AI Act ➔ Projeter l'Annexe A (Slide 12) :**

   > *« Comme synthétisé sur mon Annexe A : le RGPD impose l'Opt-In, le droit à l'oubli sous 30j (Art. 17) et le droit d'accès (Art. 15) sous peine de 4% du CA mondial ; le CCPA/CPRA californien impose le droit d'Opt-Out ("Do Not Sell My Personal Information") sur le profilage publicitaire ; PCI-DSS Exigence 7 impose la restriction stricte need-to-know sur* `payment_details` *; et l'EU AI Act exige la gouvernance des datasets d'entraînement (absence de biais, DVC/MLflow). »*

2. **Si le jury questionne sur la traçabilité IA de Discover Weekly ou le Droit à l'Oubli dans le ML ➔ Projeter l'Annexe B (Slide 13) :**

   > *« Sur l'Annexe B, vous voyez les 5 étapes de notre Lineage IA : 1) Vérification automatique du flag de consentement* OneTrust *avant ingestion ; 2) Filtrage* Talend *(suppression des écoutes bots < 30 secondes, dates ISO) ; 3) Hash immuable de la matrice utilisateurs-morceaux sous DVC enregistré dans* OpenMetadata *; 4) Tracking MLflow ; 5) Monitoring continu de la diversité musicale contre les bulles de filtres. »*

3. **Si le jury questionne sur que faire en cas de fuite de données bancaires ➔ Projeter l'Annexe C (Slide 14) :**

   > *« Notre plan de réponse en 72h (Art. 33 & 34 RGPD) présenté en Annexe C suit 4 jalons stricts : H+0 à H+4 Détection par le SIEM* Splunk*, révocation des clés et isolation réseau ; H+4 à H+24 Forensics par le Data Custodian et SecOps ; H+24 à H+48 Évaluation juridique du risque par le DPO ; H+48 à H+72 Notification officielle à l'autorité chef de file (IMY en Suède) et aux abonnés impactés. »*